EXOS AEROSPACE SYSTEMS & TECHNOLOGIES, INC.

DEF-SYSENG

Version 1

Generated August 13, 2026

Confidential — Internal Use Only

Table of Contents

1. Purpose
2. Scope
3. Responsibilities
4. Architectural Design and Security Engineering Principles
5. Security Testing & Monitoring
6. Incident Response & Continuous Improvement
7. Review & Maintenance

DEF-SYSENG

1. Purpose

This SOP establishes security engineering principles and architectural designs to enhance information security across the organization's systems. It aligns with NIST SP 800-171 Rev. 2, DFARS 7012, and CMMC 2.0 Level 2 compliance requirements. The organization employs Microsoft Defender for Endpoint, Cloudflare, Duo, Microsoft Intune, Microsoft Entra ID (formerly Azure AD), and Conditional Access Policies to implement these principles.

2. Scope

This SOP applies to all organizational systems handling Controlled Unclassified Information (CUI). It covers security engineering design, implementation, and verification, ensuring compliance with NIST 800-171, DFARS 7012, and CMMC 2.0 Level 2.

3. Responsibilities

- **Security Admin** - Configure and maintain security settings. Implements, tests, and verify security measures. Integrate security into software development.
- **Company Admin** - Oversees the implementation of security engineering principles.
- **User** – Adhere to security principles and protocols.

4. Architectural Design and Security Engineering Principles

4.1 Architectural Designs that Promote Security

- Defense-in-Depth (Layered Security Model)
  - Use multiple layers of security to mitigate risks at different levels.
  - Implement Microsoft Defender for Endpoint for endpoint protection.
  - Utilize Cloudflare Zero Trust for network security and web filtering.
- Zero Trust Architecture (ZTA)
  - Assume no implicit trust and validate access based on identity, device health, and risk-based policies.
  - Implement Conditional Access Policies in Microsoft Entra ID to enforce identity-based controls.
  - Use Duo MFA for multi-layer authentication security.
- Secure Configuration Management
  - Define and enforce baseline security configurations using Microsoft Intune.

- Ensure automatic updates using Microsoft Intune, Automox and device compliance for all managed devices.
- Implement configuration and policy enforcement using Microsoft Intune.

4.2 Secure Software Development Techniques (as applicable)

- Secure Software Development Lifecycle (SSDLC)
  - Incorporate security at every phase of the Software Development Life Cycle (SDLC).
  - Use secure coding practices, automated security testing, and code reviews to ensure security is not an afterthought.
  - Apply NIST SP 800-160 principles to integrate security controls from requirements gathering to maintenance.
- Threat Modeling and Risk Analysis
  - Identify potential threat actors, attack vectors, and vulnerabilities early in the development process.
  - Implement compensating controls to mitigate identified risks.
- Least Privilege and Secure Access Control
  - Apply Role-Based Access Control (RBAC) and Principle of Least Privilege to limit user and system access using Microsoft Entra ID.
  - Ensure applications do not run with excessive permissions unless explicitly required.
  - Utilize Conditional Access Policies in Microsoft Entra ID and Multi-Factor Authentication (MFA) via Duo.

4.3 Systems Engineering Principles

- Defense-in-Depth: Layered security controls implemented at multiple levels both for identity and network.
- Least Privilege Access: Enforced through Microsoft Entra ID.
- Multi-Factor Authentication (MFA): Duo and Microsoft Authenticator enforce MFA for privileged access.
- Automated Log Analysis: Microsoft Defender for Endpoint and Microsoft Sentinel monitor and respond to threats.

5. Security Testing & Monitoring

- Automated Security Scans: Conducted via Microsoft Defender.
- Audit Log Reviews: Quarterly reviews ensure compliance .

6. Incident Response & Continuous Improvement

1. Detection & Analysis: Microsoft Defender and Microsoft Sentinel detects anomalies.
2. Containment & Eradication: Compromised accounts/devices isolated via Defender and Entra ID.
3. Recovery & Review: *Security Admin* updates policies as needed .

7. Review & Maintenance

Annual Policy Review: Updates based on emerging threats

Revision History

Version	Date	Author	Change Summary
v1	Aug 11, 2026	nathaniel@atomus-cyber.com	Initial publication of "DEF-SYSENG".

Acknowledgement & Signature

By signing below, the undersigned acknowledges that the contents of DEF-SYSENG (Version 1) have been reviewed and approved on behalf of Exos Aerospace Systems & Technologies, Inc..

Point of Contact

NAME

Jquinn

TITLE

Chief Executive Officer, Co-Founder

SIGNATURE

DATE

Aug 13, 2026

Signed electronically on Aug 13, 2026